

OWASP Top 10

Authentication Failures

BIG school

BIGSEIO

GENERAMOS
NEGOCIO

Authentication Failures

Índice

- Introducción
- ¿Qué significa "Authentication Failures"?
- ¿Por qué ocurre esta vulnerabilidad?
- Ejemplos reales y típicos
- ¿Qué puede hacer un atacante si explota esto?
- ¿Cómo detectarlo?
- ¿Cómo prevenirlo?
- ¿Cómo mitigar si ya estás afectado?
- Checklist rápido
- Conclusiones



Authentication Failures

BIG school

BIGSEIO

GENERAMOS
NEGOCIO

Introducción

- La autenticación es la primera línea de defensa
- La mayoría de los ataques explotan logins mal protegidos
- Afecta credenciales, sesiones, recuperación y MFA
- Objetivo: implementar flujos de identidad robustos y modernos

¿Qué significa "Authentication Failures"?

- Debilidades en gestión de identidad y validación de usuarios
- Cubre creación, almacenamiento y verificación de credenciales
- Incluye sesiones, recuperación y protección contra automatización
- Si falla aquí, el atacante entra como usuario legítimo

¿Por qué ocurre esta vulnerabilidad?

- Políticas de contraseñas débiles o por defecto
- Almacenamiento inseguro (texto plano, hashes débiles)
- Sesiones sin expiración, predecibles o sin rotación
- Recuperación con fugas de información o tokens reutilizables
- Ausencia o mala implementación de MFA y rate limiting

Ejemplos reales y típicos

- Credenciales por defecto o filtradas (credential stuffing)
- Hashes inseguros (MD5/SHA-1) o sin salt único
- Session fixation o cookies sin flags de seguridad
- Enlaces de recuperación sin expiración o tokens reutilizables
- JWT/API Keys con expiración larga, algoritmos débiles o sin revocación

¿Qué puede hacer un atacante si explota esto?

- Account Takeover (ATO) y suplantación de identidad
- Escalada de privilegios (acceso a admin o servicios)
- Secuestro de sesiones activas sin necesidad de contraseña
- Exfiltración masiva de datos personales o financieros
- Daño reputacional y sanciones por incumplimiento normativo

¿Cómo detectarlo?

- **Desarrollo:** SAST y code review de hashes, cookies y flujos de login
- **Testing:** simulación controlada de fuerza bruta y pruebas de invalidación
- **Producción:** alertas por picos de intentos fallidos o logins inusuales
- **Señales:** tokens válidos tras logout, cookies sin flags, recuperación insegura

¿Cómo prevenirlo?

- Hashing moderno: Argon2id, bcrypt o scrypt con salt único
- MFA obligatorio: FIDO2 o TOTP (evitar SMS como único factor)
- Sesiones seguras: rotación, expiración, flags HttpOnly, Secure, SameSite
- Protección anti-automatización: rate limiting y bloqueo progresivo
- JWT/API seguros: algoritmos fuertes, expiración corta, refresh tokens rotativos
- Recuperación segura: sin enumeración de usuarios, tokens únicos y efímeros

¿Cómo mitigar si ya estás afectado?

1. Invalidar sesiones activas y revocar tokens/refresh tokens
2. Forzar restablecimiento de contraseñas y activar MFA
3. Aplicar rate limiting y reglas WAF contra credential stuffing
4. Parchear flujos: hashing seguro, flags de cookies, recuperación corregida
5. Auditar logs previos para detectar acceso indebido o exfiltración
6. Notificar a usuarios afectados y actualizar playbooks de respuesta

Checklist rápido

- ✓ ¿Hashing moderno (Argon2/bcrypt) y validación contra filtraciones?
- ✓ ¿Rate limiting y protección contra credential stuffing/fuerza bruta?
- ✓ ¿Sesiones con expiración, rotación y cookies seguras?
- ✓ ¿MFA habilitado para cuentas críticas y accesos sensibles?
- ✓ ¿Recuperación sin enumeración y con tokens efímeros?
- ✓ ¿JWT/API Keys con expiración corta y revocación activa?
- ✓ ¿Logging y alertas para logins, fallos y cambios de credenciales?

Conclusiones

- La autenticación es la base: si falla, el resto se debilita
- Priorizar longitud de contraseñas, MFA moderno y sesiones efímeras
- Implementar defensa en capas: hashing, rate limiting, auditoría y monitoreo
- Como desarrollador: validar cada flujo y proteger credenciales y sesiones
- Autenticación segura no es un extra: es un requisito fundamental



¡MUCHAS GRACIAS!

BIG school

BIGSEO

**GENERAMOS
NEGOCIO**